COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.2 · Risk Analysis

Mestre CyberSec · **Lesson 5.2 — Risk Analysis** (9:13) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Análise: qualitativa (alto/médio/baixo) vs quantitativa ($ — SLE × ARO = ALE); risk appetite (o que a organização ACEITA — board define); risk tolerance (variação aceitável por área); risk register.

💡 Key Exam Highlights & Critical Concepts

- ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo
- Appetite: o RISCO que aceita; tolerance: variação por área (operacional)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'accepting a specific risk level per business unit'=risk tolerance

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.2 — Risk Analysis)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Single Loss Expectancy (SLE)

The monetary value expected from a single occurrence of a risk event. Calculated as Asset Value × Exposure Factor (EF).

⚠️ ***Exam Trap:*** *SLE is NOT annualized — it is per-incident. If the question says 'per occurrence' or 'one event', it's SLE, not ALE.*

• Annualized Rate of Occurrence (ARO)

The estimated frequency with which a threat is expected to occur within a single year (e.g., 0.5 = once every 2 years, 4 = four times per year).

⚠️ ***Exam Trap:*** *ARO can be a fraction. If a flood happens 'once every 5 years', ARO = 0.2 — this directly multiplies into the ALE formula.*

• Annualized Loss Expectancy (ALE)

The expected monetary loss from a risk over a one-year period. Formula: ALE = SLE × ARO. Used to justify security control costs in cost/benefit analysis.

⚠️ ***Exam Trap:*** *ALE = SLE × ARO is the only formula to memorize for the exam. If a control costs less than the ALE, it is generally worth implementing.*

• Qualitative Risk Analysis (N/A)

A subjective, scenario-based risk assessment that uses ratings such as high/medium/low or red/yellow/green instead of dollar values; relies on expert judgment.

⚠️ ***Exam Trap:*** *If the question mentions 'high/medium/low' or 'scenario-based' or 'subjective rating', it is qualitative — not quantitative. It does NOT produce dollar amounts.*

• Quantitative Risk Analysis (N/A)

An objective, numeric risk assessment that assigns dollar values to risk using SLE, ARO, and ALE calculations.

⚠️ ***Exam Trap:*** *Any question showing actual dollar/currency values or asking you to calculate SLE, ARO, or ALE is quantitative. Hard data vs. soft ratings is the key distinction.*

• Risk Appetite (N/A)

The overall amount and type of risk the organization is willing to accept in pursuit of its objectives, defined at the board/executive level.

⚠️ ***Exam Trap:*** *Appetite is set by the BOARD/senior leadership — it is the BROAD, organizational-level statement of acceptable risk (e.g., 'we will not accept risks that could cause bankruptcy').*

- **Risk Tolerance (N/A)**

The acceptable variance from the risk appetite, typically defined per business unit, department, or system; more granular and tactical than appetite.

⚠️ ***Exam Trap:*** *Exam phrase trigger: 'accepting a specific risk level per business unit' = risk TOLERANCE. Appetite = organization-wide, Tolerance = per business unit/department.*

- **Risk Register (N/A)**

A central document or repository that lists identified risks, their likelihood, impact, owner, mitigation status, and residual risk level.

⚠️ ***Exam Trap:*** *The risk register is the OUTPUT of the risk identification process and the input to ongoing risk monitoring. Know that it tracks ownership and mitigation progress.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial services firm is performing a quantitative risk assessment for its customer database. The database is valued at $500,000. A successful breach would expose 20% of the records, and industry data indicates such an event is expected once every four years. What is the annualized loss expectancy (ALE)?

A) $25,000

B) $100,000

C) $125,000

D) $500,000

QUESTION 2 · EXAM SCENARIO

A risk analyst is calculating the single loss expectancy (SLE) for a payroll server. The server has an asset value of $120,000. If a ransomware attack succeeds, the team estimates that 35% of the server's value would be lost. What is the SLE?

A) $78,000

B) $42,000

C) $120,000

D) $155,000

QUESTION 3 · EXAM SCENARIO

A small startup has no reliable historical loss data and needs to prioritize cybersecurity risks quickly. The CISO asks the team to rate each risk as high, medium, or low based on likelihood and impact using a heat map. Which type of risk analysis is being used?

A) Annualized loss expectancy analysis

B) Business impact analysis

C) Qualitative risk analysis

D) Quantitative risk analysis

QUESTION 4 · EXAM SCENARIO

The board of directors states that the organization is willing to accept moderate risk to accelerate cloud adoption but will not accept risk that could affect patient safety data. What does this statement primarily define?

A) Risk tolerance

B) Risk register

C) Single loss expectancy

D) Risk appetite

QUESTION 5 · EXAM SCENARIO

A company has a moderate overall risk appetite. However, its e-commerce platform must not be unavailable for more than 15 minutes, while the internal HR system can be down for up to 4 hours. What does this difference illustrate?

A) Risk appetite

B) Risk tolerance

C) Annualized rate of occurrence

D) Exposure factor

QUESTION 6 · EXAM SCENARIO

After completing a risk assessment, a GRC analyst needs to document each identified risk, its owner, likelihood, impact, score, treatment plan, and current status. Where should this information be recorded?

A) Asset inventory

B) Vulnerability scan report

C) Risk register

D) Service level agreement

QUESTION 7 · EXAM SCENARIO

A company calculates that a web application attack has an SLE of $50,000 and an ARO of 2.0, producing an ALE of $100,000. After implementing a web application firewall, the ARO is reduced to 0.5 while the SLE remains $50,000. What is the annualized loss expectancy reduction?

A) $75,000

B) $25,000

C) $50,000

D) $100,000

QUESTION 8 · EXAM SCENARIO

A hospital wants to justify cybersecurity spending by estimating the expected annual monetary loss from ransomware. The team has internal incident records and industry breach cost data. Which approach best fits this requirement?

A) Qualitative risk analysis

B) Risk appetite definition

C) Risk register maintenance

D) Quantitative risk analysis

QUESTION 9 · EXAM SCENARIO

A risk analyst is calculating the annualized rate of occurrence (ARO) for a flood that historical data indicates happens once every 20 years. What ARO should be used?

A) 0.20

B) 0.05

C) 5.0

D) 20.0

QUESTION 10 · EXAM SCENARIO

A company identifies a high-risk finding in its customer portal. The team implements a compensating control, reducing the risk to a low residual level that management accepts. What should the risk analyst do next?

A) Update the risk register with the residual risk, treatment, and acceptance status

B) Remove the risk from the risk register because a control was implemented

C) Close the vulnerability scan report without documenting the decision

D) Change the risk appetite to match the residual risk level

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — $25,000

SLE = asset value × exposure factor = $500,000 × 0.20 = $100,000. ARO = 1 event / 4 years = 0.25. ALE = SLE × ARO = $100,000 × 0.25 = $25,000.

Question 2: Option B — $42,000

SLE = asset value × exposure factor. Here, $120,000 × 0.35 = $42,000. The other values do not correctly apply the exposure factor.

Question 3: Option C — Qualitative risk analysis

Qualitative risk analysis uses subjective ratings such as high, medium, and low, often with a heat map, when numerical data or time is limited. Quantitative analysis uses monetary values and calculations such as SLE, ARO, and ALE. Business impact analysis focuses on critical business functions and recovery requirements.

Question 4: Option D — Risk appetite

Risk appetite is the overall amount and type of risk the organization is willing to accept, and it is typically defined by senior leadership or the board. Risk tolerance is the acceptable variation around that appetite for specific areas or systems.

Question 5: Option B — Risk tolerance

Risk tolerance is the acceptable deviation from the overall risk appetite for a specific system, department, or process. The company accepts moderate risk overall but tolerates different availability-risk levels for different systems.

Question 6: Option C — Risk register

A risk register is the central record used to track identified risks, owners, ratings, treatment decisions, and status. Asset inventory lists assets, vulnerability reports list technical findings, and SLAs define service commitments.

Question 7: Option A — $75,000

Before control, ALE = $50,000 × 2.0 = $100,000. After control, ALE = $50,000 × 0.5 = $25,000. The reduction is $100,000 – $25,000 = $75,000.

Question 8: Option D — Quantitative risk analysis

Quantitative risk analysis uses numerical and monetary data, such as SLE, ARO, and ALE, to estimate expected annual loss. This is appropriate when historical and industry data are available and budget justification requires financial figures.

Question 9: Option B — 0.05

ARO is the expected frequency per year. If an event happens once every 20 years, ARO = 1 / 20 = 0.05.

Question 10: Option A — Update the risk register with the residual risk, treatment, and acceptance status

The risk register should be updated to reflect the treatment applied, residual risk level, owner, and management acceptance. Risks are not simply deleted after mitigation because residual risk and acceptance decisions still need tracking.